

7. Cenários de Perda

Esta seção apresenta a continuidade da aplicação da análise System-Theoretic Process Analysis (STPA) ao controlador InfoPrivSec e à sua ação de controle Review Code, contemplando especificamente a Etapa 4 - Identificação de Cenários de Perda.

Para cada uma das Ações de Controle Inseguras (Unsafe Control Actions – UCAs) selecionadas na Etapa 3 (UCA-IP-1, UCA-IP-4, UCA-IP-7 e UCA-IP-10), foi elaborado o seu respectivo cenário de perda correspondente. Cada cenário foi estruturado com base nos oito elementos exigidos: (i) UCA relacionada; (ii) Controladores envolvidos; (iii) Arquétipo do cenário; (iv) Cenário de alto nível; (v) Solução de alto nível; (vi) Cenário refinado; (vii) Fatores causais; e (viii) Solução refinada.

Em conformidade com as diretrizes da Task 7, os cenários apresentados foram desenvolvidos desconsiderando falhas de componentes como fatores causais primários. Assume-se, portanto, que todos os controladores e elementos tecnológicos operam de acordo com suas especificações de projeto. Sob essa perspectiva sociotécnica, as condições de perigo emergem de interações sistêmicas inadequadas, modelos de processo (process models) falhos ou desalinhados, mecanismos de feedback insuficientes e conflitos entre os objetivos operacionais do pipeline.

7.1. Cenário de Perda 1 - Relacionado à UCA-IP-1

Tabela 3. Cenário de Perda: UCA-IP-1

UCA Relacionada	UCA-IP-1: A InfoPrivSec NÃO FORNECE a ação de controle Review Code quando a Pull Request modifica lógica de autenticação, autorização ou controle de acesso, e a alteração é integrada à branch principal sem revisão. [H-1, H-2]
Controladores Envolvidos	• InfoPrivSec; • PR Management; • Developer.
Arquétipo do Cenário	Classe 2 - Feedback Inadequado / Falta de Informação para o Controlador.
Cenário de Alto Nível	O feedback recebido pelo InfoPrivSec a partir do PR Management era tecnicamente correto, mas não continha informação suficiente para que a InfoPrivSec identificasse a necessidade de revisão obrigatória, resultando na ausência da ação de controle Review Code.
Solução de Alto Nível	O PR Management deve sinalizar explicitamente, como parte do feedback rotineiro enviado à InfoPrivSec, sempre que uma submissão alterar arquivos ou módulos associados a autenticação, autorização ou controle de acesso.
Cenário Refinado	Um desenvolvedor abre uma Pull Request que modifica o middleware de autorização de API responsável por validar o escopo de permissões de acesso a prontuários eletrônicos. O PR Management opera exatamente conforme especificado: gera corretamente o status da PR, calcula a cobertura de testes e disponibiliza esses dados à InfoPrivSec através do canal de feedback padrão (PR Status).

	Entretanto, o PR Management não foi projetado para classificar automaticamente o tipo de módulo afetado pela alteração; ele apenas informa que a PR está 'pronta para revisão', sem destacar que o conteúdo da mudança envolve lógica de controle de acesso. A InfoPrivSec, por sua vez, gerencia uma fila com dezenas de PRs pendentes e prioriza a revisão com base na contagem de linhas alteradas, conforme seu modelo de processo interno, uma heurística adotada porque historicamente PRs pequenas tendiam a ser de baixo risco. Como a alteração no middleware envolve poucas linhas de código (uma mudança em uma condição de verificação de papel), a InfoPrivSec a classifica como baixa prioridade em seu modelo de processo e não chega a revisá-la dentro do prazo do sprint. O Pipeline Orchestrator, operando corretamente segundo a configuração vigente, que não exige bloqueio por aprovação explícita da InfoPrivSec para PRs pequenas, permite que o Developer realize o merge. Nenhum componente falhou: o PR Management informou o que estava configurado para informar, a InfoPrivSec seguiu sua heurística de priorização, e o Pipeline Orchestrator aplicou exatamente a política configurada. A condição perigosa surgiu da combinação entre um modelo de processo que usa tamanho da PR como proxy de risco e a ausência de um sinalizador estrutural que diferencie 'PR pequena e de baixo risco' de 'PR pequena, porém crítica para o controle de acesso'.
Fatores Causais	• Modelo de processo da InfoPrivSec baseado em heurística inadequada (tamanho da PR) para estimar risco de privacidade/segurança; • Ausência de feedback estruturado do PR Management indicando o tipo de módulo afetado (autenticação/autorização); • Configuração do Pipeline Orchestrator não exige aprovação obrigatória da InfoPrivSec antes do merge para PRs classificadas como pequenas.
Solução Refinada	• Implementar classificação automática de PRs por caminho de arquivo afetado (ex.: módulos de auth/, middleware/, rbac/) e exibir esse rótulo no feedback enviado à InfoPrivSec, independentemente do tamanho da alteração; • Configurar o Pipeline Orchestrator (gate de merge) para exigir aprovação explícita da InfoPrivSec sempre que o rótulo de 'controle de acesso' estiver presente, removendo a contagem de linhas como critério de dispensa; • Reforça diretamente a CLC-IP-1, tornando a obrigatoriedade da revisão verificável tecnicamente, e não apenas dependente do julgamento do revisor.

7.2. Cenário de Perda 2 - Relacionado à UCA-IP-4

Tabela 4. Cenário de Perda: UCA-IP-4

UCA Relacionada	UCA-IP-4: A InfoPrivSec FORNECE a ação de controle Review Code, aprovando a PR, quando a alteração introduz dados sensíveis de saúde em logs, mensagens de erro ou mecanismos de observabilidade, sem identificar a exposição. [H-1, H-3]
Controladores Envolvidos	• InfoPrivSec; • Developer; • Site Reliability Engineer (SRE).

Arquétipo do Cenário	Classe 1 - Comportamento Inseguro do Controlador.
Cenário de Alto Nível	A InfoPrivSec realizou a revisão dentro do escopo que considerava adequado, mas seu modelo de processo não contemplava a verificação de caminhos de log e observabilidade como parte rotineira da checklist de aprovação.
Solução de Alto Nível	Incluir explicitamente, na checklist formal de revisão da InfoPrivSec, a verificação de todo caminho de código que grave dados em logs, mensagens de erro ou ferramentas de monitoramento.
Cenário Refinado	Um Developer implementa uma melhoria no tratamento de exceções de um serviço clínico, adicionando uma chamada de log que registra o objeto completo da exceção para fins de depuração, incluindo, sem intenção maliciosa, o payload da requisição que contém o nome completo e o diagnóstico do paciente. O código está sintaticamente correto, passa todos os testes automatizados e a varredura de segurança aprova a submissão, pois nenhum padrão de vulnerabilidade técnica conhecida está presente. A InfoPrivSec realiza a revisão da PR de forma genuína e atenta, examinando a lógica de negócio, a cobertura de testes e a ausência de vulnerabilidades de segurança tradicionais (injeção, autenticação). Seu modelo de processo e sua checklist de revisão, construídos a partir das diretrizes vigentes da organização, focam primariamente em controle de acesso e validação de entrada, sem incluir, como item obrigatório, a inspeção de chamadas de logging quanto à presença de dados pessoais. A InfoPrivSec aprova a PR de boa-fé, certificando-a como segura. O SRE, ao receber posteriormente um alerta de erro real em produção, observa nos logs do sistema de observabilidade o conteúdo completo da exceção e, com isso, dados sensíveis do paciente passam a residir em um sistema de monitoramento de terceiros acessível à equipe de operações, fora dos controles de acesso da aplicação principal. Nenhum componente falhou: o Developer escreveu código funcional, o scanner avaliou corretamente o que estava em seu escopo, a InfoPrivSec seguiu sua checklist vigente com atenção, e o SRE apenas observou o comportamento esperado da ferramenta de observabilidade. O perigo nasceu de uma lacuna estrutural na definição do escopo de revisão da InfoPrivSec, que nunca incluiu logging como uma superfície de risco de privacidade.
Fatores Causais	• Checklist formal de revisão da InfoPrivSec não contempla verificação de exposição de dados pessoais em logs, mensagens de erro ou observabilidade; • Varredura automatizada de segurança não é projetada para detectar PII/PHI em chamadas de logging; • Ausência de padronização (ex.: biblioteca de logging com mascaramento automático) que reduza a dependência da revisão manual para esse risco específico.
Solução Refinada	• Atualizar formalmente a checklist de revisão da InfoPrivSec para incluir item obrigatório de verificação de chamadas de log/erro/observabilidade quanto à presença de dados pessoais sensíveis; • Adotar biblioteca de logging padronizada com mascaramento automático de campos sensíveis conhecidos, reduzindo a dependência exclusiva da revisão manual;

	• Implementa diretamente a CLC-IP-4, tornando a exigência de mascaramento/remoção verificável antes da aprovação.
--	---

7.3. Cenário de Perda 3 - Relacionado à UCA-IP-7

Tabela 5. Cenário de Perda: UCA-IP-7

UCA Relacionada	A InfoPrivSec FORNECE a ação de controle Review Code CEDO DEMAIS (antes de aguardar os resultados dos scans automatizados de segurança, como SAST/DAST) em um Pull Request contendo vulnerabilidades não aparentes, resultando na aprovação de código inseguro. [H-1, H-3, H-4]
Controladores Envolvidos	• InfoPrivSec; • Pipeline Orchestrator;
Arquétipo do Cenário	Classe 2 (Feedback/Informação)
Cenário de Alto Nível	A InfoPrivSec aprova a revisão do código (Review Code) prematuramente porque a ferramenta do Pipeline Orchestrator (SAST/DAST) demora muito para concluir os scans e não há um bloqueio sistêmico na interface que impeça a aprovação antes da conclusão da varredura.
Solução de Alto Nível	O sistema de repositório deve exigir que as verificações automatizadas de segurança (SAST/DAST) sejam concluídas com sucesso antes de habilitar o botão de Review Code (Aprovação) para a InfoPrivSec.
Cenário Refinado	1. Um desenvolvedor submete um Pull Request (PR) contendo uma vulnerabilidade sutil. 2. O Pipeline Orchestrator inicia os testes e scans de SAST/DAST, porém a fila de processamento está sobrecarregada, atrasando os resultados. 3. A InfoPrivSec acessa o PR e realiza a revisão manual. 4. Devido à pressão do prazo de entrega, a InfoPrivSec não aguarda os resultados automatizados (que ainda estão rodando) e assume, com base na revisão manual, que o código está seguro. 5. A InfoPrivSec emite a ação Review Code (aprovando o PR). 6. O código com a vulnerabilidade é integrado. Posteriormente, a ferramenta SAST finaliza e reporta o erro, mas a integração já ocorreu.
Fatores Causais	- Modelo Mental Falho: A InfoPrivSec acredita que a revisão manual é suficiente para identificar vulnerabilidades quando o scan automatizado está muito lento. - Pressão de Prazos/Comportamento Inseguro: Pular etapas devido à urgência de releases. - Falha de Design na Interface: A interface permite que a ação de controle de aprovação seja executada enquanto os scans de segurança estão em andamento.
Solução Refinada	- Implementar políticas rígidas de Branch Protection que desabilitem ativamente a possibilidade de fornecer o Review Code (Aprovação) até que todos os fluxos de trabalho (SAST/DAST) essenciais reportem status de "Sucesso".

	- Adicionar um indicador visual de "Varredura em Andamento - Aguarde" na interface de revisão de PR.
--	--

7.4. Cenário de Perda 4 - Relacionado à UCA-IP-10

Tabela 6. Cenário de Perda: UCA-IP-10

UCA Relacionada	A InfoPrivSec INTERROMPE MUITO CEDO a ação de controle <i>Review Code</i> (realizando uma análise apenas parcial dos arquivos modificados em um PR extenso) em um módulo que afeta os dados sensíveis dos pacientes, falhando em detectar trechos de código maliciosos ou vulneráveis. [H-1, H-2, H-3]
Controladores Envolvidos	InfoPrivSec
Arquétipo do Cenário	Classe 1 (Comportamento do Controlador)
Cenário de Alto Nível	A InfoPrivSec se depara com um Pull Request massivo contendo dezenas de arquivos alterados; ela revisa apenas os arquivos principais, assume que os demais são secundários e encerra a revisão precocemente, aprovando o código que contém vazamento de dados nos arquivos ignorados.
Solução de Alto Nível	Modificar a estrutura e as políticas do processo de desenvolvimento para evitar Pull Requests muito grandes e garantir métricas que rastreiem a completude da revisão humana.
Cenário Refinado	1. Uma grande atualização de arquitetura (refatoração) do SisAPEC gera um PR com mais de 50 arquivos modificados. 2. A InfoPrivSec inicia a ação de <i>Review Code</i>. 3. Após revisar os primeiros 15 arquivos, a InfoPrivSec se sente fadigada ("fadiga de revisão") e nota que a janela para a <i>release</i> está se fechando. 4. A InfoPrivSec assume que as alterações restantes são apenas triviais ou arquivos de configuração sem impacto de segurança. 5. Ela INTERROMPE CEDO DE MAIS o <i>Review Code</i> detalhado e aprova o PR inteiro. 6. Um dos arquivos não revisados continha uma lógica que desativava os logs de auditoria exigidos pela LGPD.
Fatores Causais	- Processo Mal Projetado: Políticas da equipe permitem a submissão de PRs monolíticos massivos, que são impossíveis de serem revisados adequadamente de uma só vez. - Fadiga/Limitação Humana: A exaustão mental leva o controlador (InfoPrivSec) a ignorar partes do processo controlado.
Solução Refinada	- Instituir restrições de pipeline que rejeitem automaticamente Pull Requests que excedam um número X de linhas de código ou Y arquivos modificados, obrigando o fracionamento das submissões.

- Exigir nas políticas de governança que PRs relacionados a dados clínicos sensíveis passem por revisão em "par" (dois revisores de InfoPrivSec) para dividir a carga de trabalho.

8. Requisitos Derivados

Com base nos cenários de perda identificados na Seção 7, foram derivados os requisitos necessários para mitigar ou eliminar as condições causais associadas aos perigos mapeados. A tabela a seguir apresenta esses novos requisitos e estabelece a rastreabilidade direta com seus respectivos cenários geradores, em estrita conformidade com o formato exemplificado na Tabela 9 das diretrizes deste projeto."

Tabela 7. Requisitos de Segurança Derivados para o Controlador InfoPrivSec com Base nos Cenários de Perda Identificados

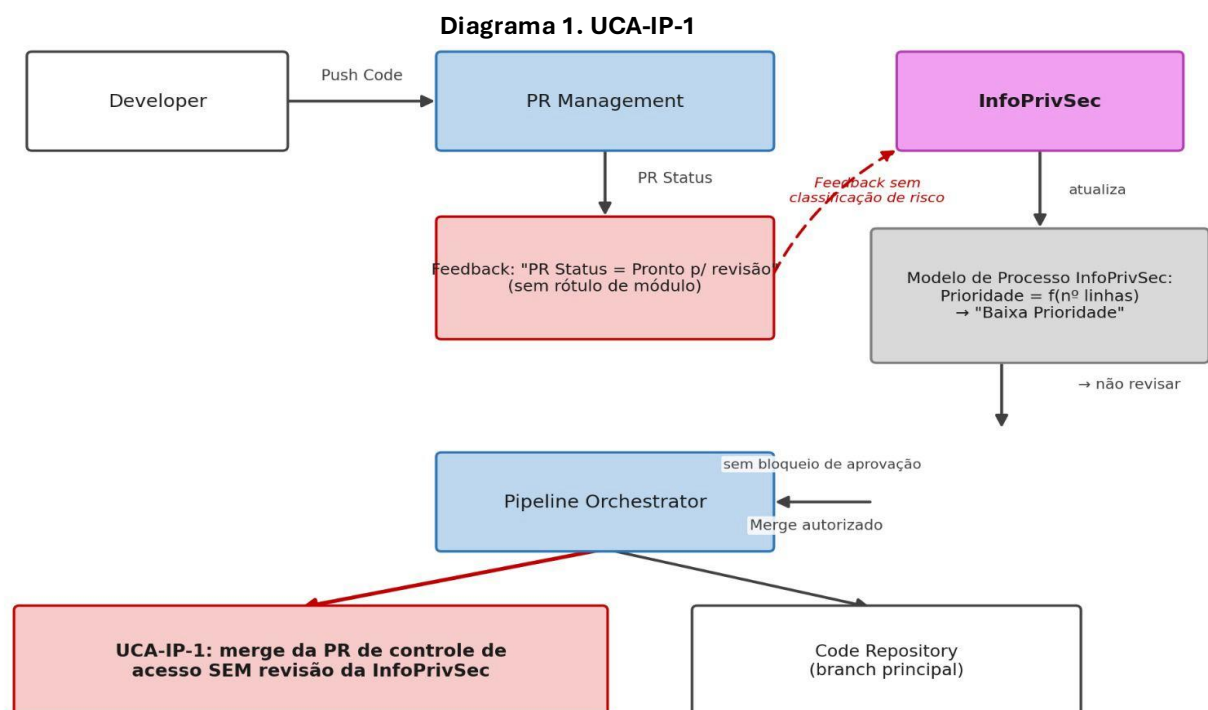
ID	Requisito Derivado	Cenário(s) Relacionado(s)
DR-1	O PR Management deve classificar automaticamente cada Pull Request quanto ao módulo afetado (ex.: autenticação/autorização, tratamento de dados pessoais), exibindo esse rótulo no feedback enviado à InfoPrivSec independentemente do tamanho da alteração.	Cenário UCA-IP-1
DR-2	O Pipeline Orchestrator deve exigir aprovação explícita da InfoPrivSec antes do merge de qualquer PR rotulada como afetando controle de acesso, eliminando a contagem de linhas como critério de dispensa.	Cenário UCA-IP-1
DR-3	A checklist formal de revisão da InfoPrivSec deve incluir item obrigatório de verificação de chamadas de log, mensagens de erro e mecanismos de observabilidade quanto à presença de dados pessoais sensíveis.	Cenário UCA-IP-4
DR-4	O SisAPEC deve adotar biblioteca de logging padronizada com mascaramento automático de campos sensíveis conhecidos, reduzindo a dependência exclusiva da revisão manual para esse risco.	Cenário UCA-IP-4
D-5	O Pipeline de CI/CD deve implementar uma trava de segurança (<i>branch protection rule</i>) que bloqueie a capacidade de mesclagem (<i>merge</i>) e impeça a finalização da revisão de código (status de aprovação) em qualquer Pull Request até que todos os relatórios de análise de segurança automatizada (SAST/DAST) tenham sido concluídos e validados como "passados" (sem vulnerabilidades de severidade alta).	Cenário UCA-IP-7
D-6	O sistema de gestão de repositório deve exigir o preenchimento de um <i>checklist</i> de revisão granular. Este <i>checklist</i> deve forçar o revisor a confirmar, item a item, a inspeção de componentes críticos (ex: módulos de criptografia, persistência de dados sensíveis, logs) antes que o botão "Aprovar" seja habilitado. Além disso, Pull Requests que excedam um limite predefinido de arquivos alterados (definido pela governança) devem	Cenário UCA-IP-10

	ser obrigatoriamente fracionados em múltiplos Pull Requests menores para garantir a exaustividade da revisão humana.	
--	--	--

9. Diagramas

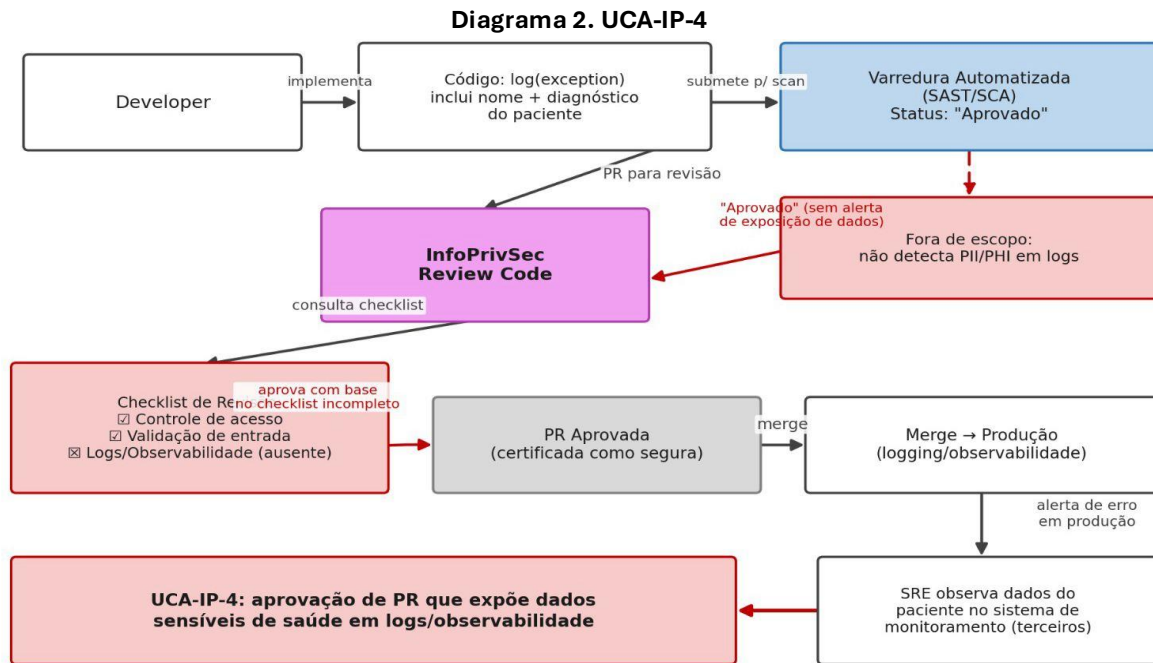
9.1. Diagrama 1 - Relacionado à UCA-IP-1

O Diagrama 1 ilustra o cenário no qual uma PR é classificada sem as informações necessárias sobre o escopo do módulo ou o risco real da alteração. A seta tracejada em vermelho indica o feedback inadequado enviado ao processo de priorização, o que induz à omissão da revisão por parte da InfoPrivSec. Como consequência, o Pipeline Orchestrator autoriza o merge da PR sem a devida validação de segurança.



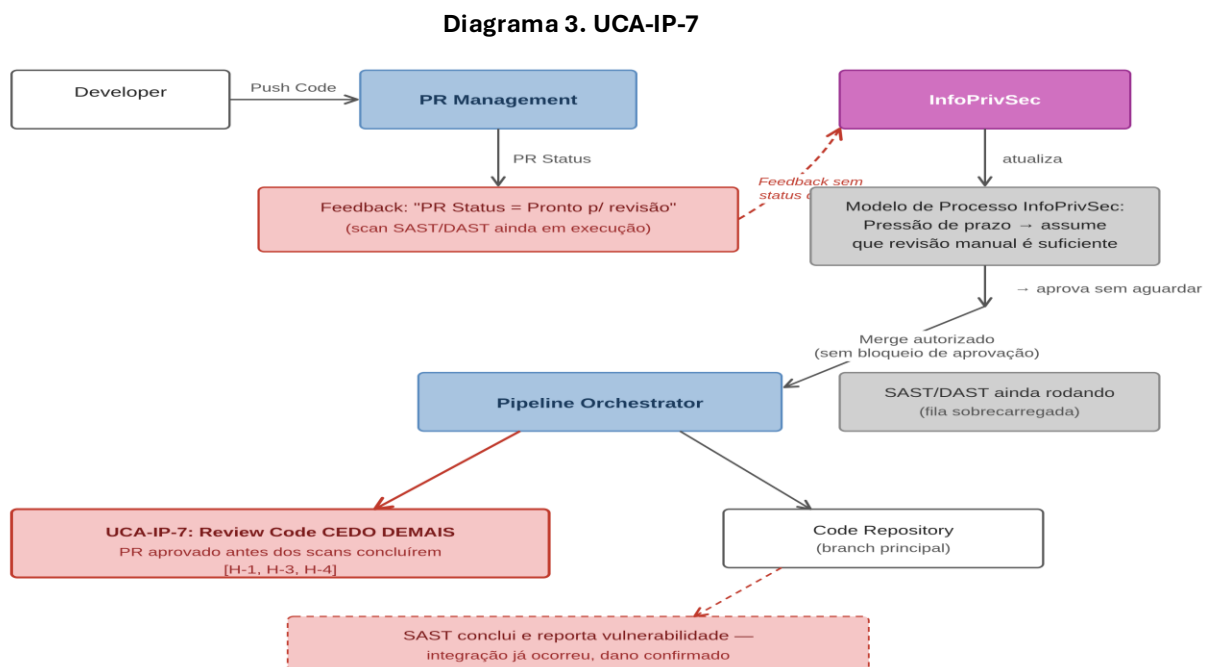
9.2 Diagrama 2 - Relacionado à UCA-IP-4

O Diagrama 2 ilustra o cenário no qual uma PR contendo dados sensíveis em logs é aprovada e implantada em produção. As marcações em vermelho destacam lacunas na detecção e na revisão: a varredura automatizada falha ao não identificar PII/PHI nos logs, e o checklist de revisão omite esse aspecto. Esse conjunto de falhas de controle resulta na exposição indevida de informações sensíveis de saúde.



9.3 Diagrama 3 - Relacionado à UCA-IP-7

O diagrama 3 ilustra o "fornecimento de ação de controle antes da disponibilidade do feedback crítico". O link tracejado em vermelho representa o momento em que a ação de controle de Review Code foi disparada, mas o feedback de Scan Results ainda não foi processado pelo controlador.



9.2 Diagrama 4 - Relacionado à UCA-IP-10

O diagrama 4 aponta que a InfoPrivSec atingiu o estado de "análise incompleta". O bloco em vermelho (Arquivo 16-50: Não revisado) visualiza a omissão de controle que caracteriza a UCA.

Diagrama 4. UCA-IP-10

